

Supporting Report

Standard AI-800-74: Section 230, the Moral Crumple Zone, and Blame Handoff as Model Capability Advances

Companion to the condensed policy artifact (Standard AI 800_74-v3). This report recovers the operational detail that was trimmed for the 1–2 page statutory format and situates the Standard in the American intermediary-liability tradition and in Madeleine Clare Elish’s work on the moral crumple zone.

1 How the artifact parallels § 230 for platforms with AI model providers

47 U.S.C. § 230 as interpreted for the social web immunizes *providers and users* of an “interactive computer service” from certain kinds of legal liability for information provided by *another* information content provider: the classic “publisher” is the user, and the host is a conduit, not a speaker (CDA 1996). The economic and normative bet was the same in 1996 that many advocates still defend today: a flat shield encourages intermediaries to build communication infrastructure, moderate in good faith (see § 230(c)(2)), and not face ruinous suits over third-party posts.

Mapping. Standard AI-800-74 preserves that **intuition** for a different technical stack. Table 1 makes the parallel explicit.

Dimension	Section 230 (social / hosting)	Standard AI-800-74 (autonomous code / deployment)
“Who is the author?”	The human user, page owner, or poster.	The <i>user intent</i> and the <i>co-produced artifact</i> ; the system sets default configuration of code, data stores, and deploy paths.
Intermediary’s core act	Host, display, and route <i>third-party</i> information.	Generate, modify, and often <i>execute</i> code, alter infra, and deploy to live runtimes on behalf of the user.
Liability off-switch (rough analogue)	Immunity for hosting others’ content (with limits, caveats, and growing contestation in courts).	Unattested track plus low Phase-Advancement Tier : default deployer liability for an “As-Is” build <i>when</i> verification was honestly disclaimed, the user is sophisticated enough to have chosen that track, and the Non-Expert carve-out does not apply.
“Good Sam” analogue	Rewards voluntary restriction of objectionable content; encourages moderation.	Attested track and a sound verification layer: strict <i>provider</i> liability for failures the layer was built to catch (and for Constructive Attestation that contradicts reality).

Table 1: Parallel between § 230 and Standard AI-800-74: same policy structure (shield productive intermediaries, reward safety investment), different technical fact pattern.

The Standard does not displace § 230 for ordinary hosting of third-party speech. It applies where the claim arises from a Covered Provider’s own generative or agentic system and its default configuration of what gets deployed.

2 Anticipating modern failures of § 230, and a blame handoff as models advance

Much contemporary debate over § 230 concerns not the statute’s 1996 text but its unanticipated scale effects: a handful of very large services set rules and defaults for billions; moderation at that scale misfits notice-and-takedown; harms (amplification, disinformation, cross-border spillovers) are structural rather than a series of one-off posts. Reform proposals therefore stress duty of care, transparency, and in some cases *ex ante* design obligations—ideas that the original bargain did not fully encode.

The analogue for generative systems. Harms from autonomous code and deployment are similarly **structural and default-driven**: a missing row-level security policy, a single shared dev/prod database, or an agent with production write access can create thousands of matching vulnerabilities at once (see documented incidents around CVE-2025-48757, Moltbook, and the 2025 Replit production-database case). A static binary immunity cannot track **model capability** (tool use, long-horizon agents, or future systems that more reliably outplan human operators in deployment workflows).

Standard AI-800-74 therefore encodes a deliberate **blame handoff**:

- **Low tier / early or narrow-risk deployments.** The regime preserves space for the same pro-innovation policy as § 230: deployer liability is available on the **Unattested** path when the user is sophisticated, track selection is real, and constructive attestation has not muddled the line between “safe” and “as-is.” The **Exception to Advancement** (24-hour proactive disclosure) rewards candid incident reporting for *tier* consequences without erasing the incident from the M4, M5, and M7 record.
- **Higher tier / more capable or mass-market systems.** As metrics M1–M7 rise, more duties attach to the provider; Tier 2 and Tier 3 restrict or eliminate Unattested deployment for non-experts and, at Tier 3, for all but vetted enterprise contracts. The **residual** fault line moves from the “clicker” toward the entity that can encode defaults.

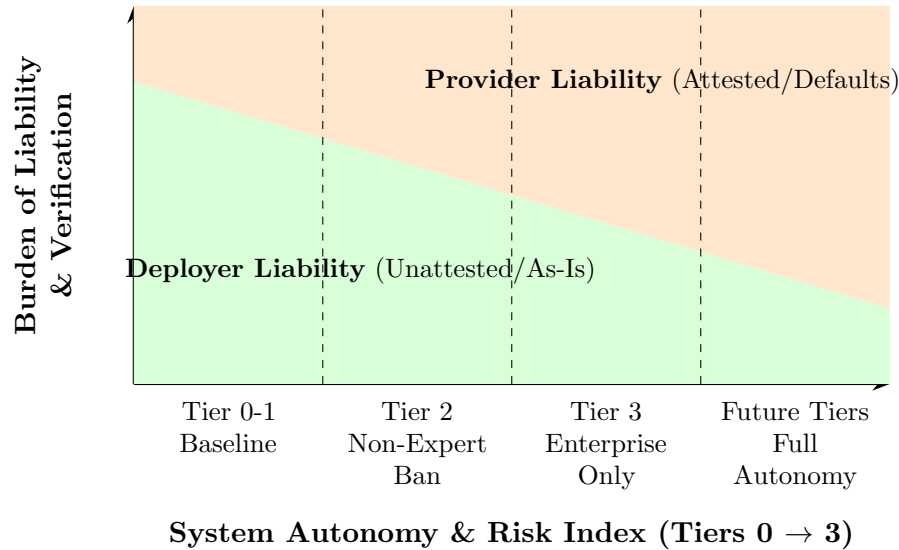


Figure 1: The Phase-Advancement Blame Handoff. As the empirical capabilities (M1-M7) of the ADA increase, the regulatory framework dynamically shrinks the legally permissible “Moral Crumple Zone” (deployer liability), shifting the verification burden to the structural actor.

3 Elish’s moral crumple zone: humans-in-the-loop and why the Standard reverses the default

In *Moral Crumple Zones: Cautionary Tales in Human-Robot Interaction*, Madeleine Clare Elish shows that in complex, partly automated systems, **blame for failure often lands on the human operator closest to the event**, even when the design of the system, the incentives, or the unrecoverable time pressure in fact made human correction impossible or unlikely (2). The “crumple zone” is the human body, institutionally, that absorbs the moral and legal impact of a failure whose structural causes lie upstream.

Connection to the artifact. A naive liability rule for generative code would re-enact the crumple zone: the **last human who clicked deploy** is the most visible actor; everyone upstream (model trainer, product manager who chose default database policies, growth team who asked for one-click launch) is harder to name in a docket. Standard AI-800-74 is written so that, at the right tier, that pattern breaks:

- **Non-Expert End User Carve-Out.** A click, even cryptographically attested, cannot move liability for a default configuration the user could not evaluate.
- **Constructive Attestation.** A chat or UI that says “safe” without an equally prominent as-is path triggers strict provider liability, so the downstream human is not the only visible actor.
- **Crumple-Zone Impact Statement (Tier 2+).** The provider must list every point where a human in the loop is the residual risk buffer and justify that choice. That is the moral-crumple zone made administrable and auditable rather than left to the accident report.

4 Technical Grounding: The Necessity of Functional Correctness Testing

The Standard explicitly requires that the Attested Generation track include functional correctness testing—specifically, generating and executing deterministic, synthetic unit tests to simulate unauthorized access and confirm negative responses.

This requirement is technically necessary to govern non-deterministic systems. When evaluating traditional code authored by humans, static analysis (SAST) that checks for the *presence* of a security policy in the syntax is often sufficient, because compilation and deterministic logic naturally enforce structure. LLMs, however, routinely generate “hallucinated structure”—code that syntactically mimics a security policy (e.g., generating an authorization middleware tag) but fails silently at runtime due to misaligned scope variables or missing dependencies.

Because LLM generation is inherently probabilistic, the verification layer must be inherently deterministic. A provider cannot legally claim a “safe deployment” merely because the LLM generated text that looks like a guardrail. The Standard operationalizes this reality by demanding that the verification pipeline actively attempt to breach the generated artifact in a sandbox before live deployment.

5 Feasibility and Enforcement Infrastructure

A central challenge of AI governance is the feasibility of regulatory oversight without grinding innovation to a halt. Standard AI-800-74 achieves institutional realism by tethering enforcement directly to the existing infrastructure of modern continuous integration and continuous deployment (CI/CD) pipelines.

CISA and NIST are not required to manually review generated codebases. Instead, the enforcement mechanism relies entirely on the **Cryptographic Deployment Signatures**. Enterprise hosting platforms already generate robust telemetry regarding deployment states, pre-commit hook execution, and SAST/DAST scanner outputs. The Standard requires ADA providers to cryptographically sign this existing telemetry at the moment of execution, appending the user-acknowledgment status and the track designation.

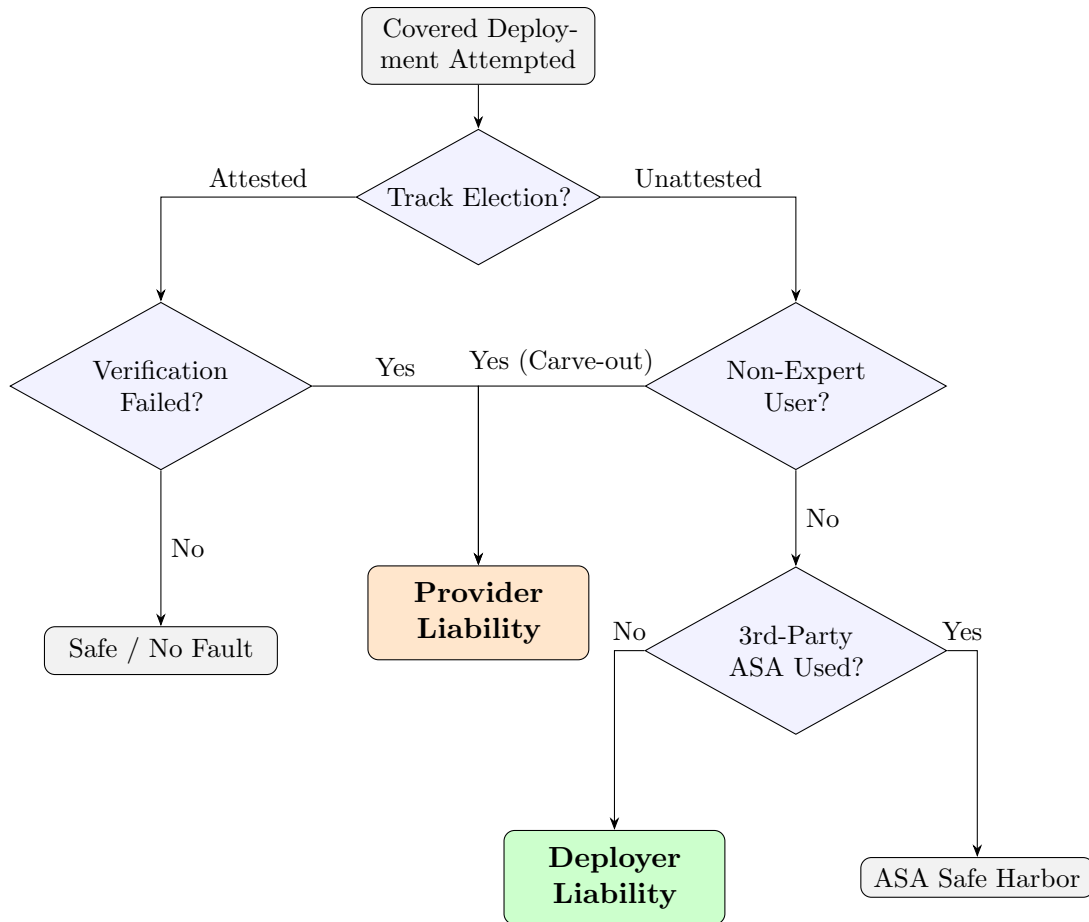


Figure 2: The Attestation-Liability Decision Tree. This flowchart provides an operational logic gate for auditors and courts to assign fault based strictly on the verifiable, machine-readable telemetry stored in the Cryptographic Deployment Signature.

This architecture makes the Standard highly scalable. In the event of a breach, CISA simply requests the cryptographic log to trace the decision tree in Figure 2, establishing legal fault lines without requiring subjective judicial review of the AI's "intent."

6 Operational detail: Phase-Advancement Audit (M1–M7)

NIST (or a designated auditor) would implement the following metrics to establish the Tier (0-3) matrix:

6.1 De minimis coverage

NIST may annualize only Covered Providers that exceed a de minimis threshold. A workable starting point: **10,000** Covered Deployments per quarter, or **100** deployments where the pipeline processes personal information of United States persons.

6.2 The seven metrics (each 0–3)

ID	Domain	Evidence and scoring
M1	Capability / autonomy of agent	0: chat; 1: IDE suggester; 2: sandboxed tools; 3: write or execute on production.
M2	User-base sophistication	Provider-estimated share of users with verifiable dev credentials, cross-checked to marketing. Score 3 when a majority of MAUs are not verified developers and the product markets to non-technical builders.
M3	Default security posture	Quarterly random sample of $N \geq 500$ generated artifacts. Score includes RLS or equivalent, secret scanning, dev/prod separation, least privilege, destructive-confirm UX. A scanner that checks only presence of a policy, not correctness of effect, should score 0 on that sub-element.
M4	Incident rate	CVSS-weighted CVEs per 100,000 Covered Deployments per quarter tied to provider-set defaults, not only user-authored patches.
M5	Realized harm	Records lost, money lost, or unauthorized destructive write; harmonized to 72-hour material-incident rules under universal duties.
M6	Concentration	Category share. Cap at 3 when HHI-style concentration passes an agreed screen or a provider exceeds, say, 15% of a relevant ADA category.
M7	Disclosure speed	Median time to fix after coordinated report; 45-day lapse without fix scores high on the metric for that cycle.

6.3 Weights and decision rule

Let each $M_i \in [0, 3]$. A practicable set of **weights** is

$$(w_1, \dots, w_7) = (0.20, 0.15, 0.20, 0.15, 0.15, 0.05, 0.10).$$

The **Phase-Advancement Tier** is the **rounded** weighted mean of M1–M7.

Overrides. A provider moves **up** at least one tier on *any* of:

- index jumps by at least 1.0 from the previous annual cycle;
- M4 is above the category 90th percentile for two consecutive quarters; or
- a Level-1 Incident: (A) $\geq 100,000$ personal records exposed, or (B) an agent-initiated unauthorized destructive write to a production data store.

A provider may dial back after two consecutive clean audit cycles and architectural remediation of the causes of the prior lift.

7 Conclusion

Standard AI-800-74 uses the **Section 230** intermediary-liability *shape* (protect development early, keep deployers in the story when honest “as-is” choice is real) but refuses to copy its **static** inflexibility. The **Phase-Advancement Audit** and the **Non-Expert** and **Constructive Attestation** rules operationalize a response to the **moral crumple zone** Elish identified: they make it harder for law to let the nearest human take all blame when the deepest control sits with the provider, especially as default-setting power and model autonomy increase.

References

[CDA 1996] 47 U.S.C. § 230, Communications Decency Act of 1996.

- [2] M. C. Elish, *Moral Crumple Zones: Cautionary Tales in Human-Robot Interaction*, Engaging Science, Technology, and Society, 5 (2019), 40–60. DOI: 10.17351/ests2019.260.